DRAFT — PENDING OWNER APPROVAL

AutoClip Information Security Policy — Candidate

- **Document ID:** AUTOCLIP-SEC-POL-CANDIDATE
- **Version:** Draft 1.2
- **Status:** DRAFT — PENDING OWNER APPROVAL
- **Prepared:** 2026-11-02
- **Accountable business operator:** 56.151.919 DIOGO NASCIMENTO DOS SANTOS, MEI holder; CNPJ 56.151.919/0001-30
- **Business name:** AutoClip
- **Location:** Rio de Janeiro/RJ, Brazil
- **Security contact:** diogos.nascimento@outlook.com
- **Approver / approval date / effective date:** PENDING OWNER DECISION

AutoClip is the trade name used by the MEI holder identified above. This candidate does not replace, approve, publish, or amend `apps/web/public/security-policy.html` or historical PDFs. Local policy sources contain conflicting version and approval statements; see `FINAL_OWNER_DECISIONS_AND_BLOCKERS.md`. The owner confirms regular review of the security contact mailbox, but this does not mean continuous or 24/7 monitoring, a response-time guarantee, or delegated coverage. This policy is not effective until formally approved. Its requirements do not prove technical deployment or operational verification.

1. Purpose and scope

This policy sets security requirements for AutoClip application code, identities and access, databases, object storage, backend functions, workers, operational accounts, information, and service providers. It applies to development, test, staging, and production. Production and provider controls must be verified in their actual environments; local code or policy text alone is not proof of deployment.

2. Governance and responsibilities

The MEI holder is the accountable business operator and coordinates security incidents. The owner is responsible for approving this policy, authorizing changes within their authority, assigning any additional roles, and retaining review evidence. Engineering personnel and service providers must use information only for assigned purposes, protect credentials, follow least privilege, and report suspected incidents promptly through the listed security contact.

The owner confirms regular review of `diogos.nascimento@outlook.com`. No 24/7 monitoring, response-time guarantee, designated delegate, or completed incident exercise is claimed. If the owner is unavailable, material incident handling and any applicable notice must follow the documented escalation and legal-review process; the absence of a delegate remains an operational gap.

3. Identity, authorization, and tenant boundaries

Access shall be based on authenticated identities, least privilege, role authorization, and workspace membership. Database row-level security (RLS), RPC authorization, backend checks, foreign keys, and Storage rules must consistently enforce workspace boundaries. Privileged server credentials must not be placed in browser-delivered code. Local migrations and tests provide evidence for parts of this design; active Cloud grants, policies, deployed function bodies, and runtime enforcement have not been established by this candidate.

4. Credential and OAuth protection

OAuth tokens shall be encrypted before persistence, accessible only to trusted server-side components, bound to the correct connection and workspace, and excluded from logs, client responses, telemetry, traces, and error messages. Rotation must use distributed coordination and version/attempt-aware conditional persistence so that stale workers cannot overwrite newer credentials. A timeout or other ambiguous provider result must not trigger an unsafe retry of a potentially invalidated refresh token; when the latest valid state cannot be established safely, the connection must require conservative reauthorization or intervention.

TikTok Login Kit and TikTok Shop are separate products and authorization contracts. Their endpoints, token lifetimes, rotation and invalidation behavior must be confirmed independently. Local cryptography, lease/CAS code, and tests do not establish that these controls are deployed or that TikTok Shop follows the Login Kit contract. The evidence matrix records implementation and deployment limits.

5. Data and media protection

AutoClip shall collect and retain only data needed for user-requested account connection, workspace operation, media handling, scheduling, publication, security, and support. Access to media and publication metadata shall be workspace-scoped. Shop product/order fields and provider raw JSON require field-level minimization before the related processing is enabled or represented as complete.

Media may be considered eligible for automatic deletion only after all of these conditions are met: publication is confirmed; at least 24 hours have elapsed as a safety window; no shared reference prevents deletion; no related operation is pending or in an unknown state; and the applicable safe-deletion checks pass. Eligibility is not the same as deletion. Automatic cleanup is not confirmed active or executed in production. Other data categories do not receive a retention period from this policy; their schedules remain pending approval and evidence.

6. Encryption and secure communications

Application and provider communications shall use approved HTTPS/TLS endpoints with certificate validation where applicable. Tokens must use authenticated encryption before persistence, with encryption keys stored separately in protected server-side configuration and access limited to authorized processes. The local application contains AES-GCM token-encryption code and synthetic tests; key provisioning, deployed code, database/Storage/backup encryption, actual TLS configuration, and provider settings require separate verification. Do not represent these local artifacts as proof of production configuration.

7. Secure development and vulnerability management

Security-sensitive changes should receive review, targeted negative tests, dependency checks, and isolated integration tests before release. Database changes require review of authorization, tenant isolation, privilege changes, locking, data preservation, compatibility, and recovery. Synthetic data shall be used in tests. Findings must be prioritized, assigned, tracked to resolution or accepted exception, and revalidated. Historical gate results are not current release evidence; current checks must be recorded with environment and command.

8. Logging and monitoring

Logs should support security investigation while minimizing personal information. Plaintext tokens, passwords, authorization codes, keys, full credential-bearing URLs, and media content must not be intentionally recorded. Access, retention, alerting, telemetry redaction, and operational log review must be verified in deployed services. The owner's regular review of the security mailbox is owner-confirmed; it is not a claim of continuous log monitoring or 24/7 incident response.

9. Incident response

The MEI holder coordinates security incidents. Suspected unauthorized access, disclosure, loss, alteration, credential compromise, cross-workspace access, malware, or material availability events must be triaged, contained, investigated, and assessed for legal, contractual, and platform notification duties. Records must be sanitized and access-controlled; corrective actions must be tracked and reviewed.

The owner confirms regular review of the security mailbox, without a guaranteed response time or continuous coverage. No delegate is confirmed and no tabletop exercise is claimed as completed. The local runbook describes steps but does not establish full operational readiness. Notification timing and recipients require assessment under applicable law, contract, and TikTok requirements.

10. Retention, deletion, backup, and recovery

Retention shall be defined by data category, purpose, and legal or contractual exception. No period is set here for accounts, tokens, publication history, logs, audit records, Shop data, or backups without supporting approval and evidence. Verified deletion requests must be scoped across relevant database, Storage, credentials, logs, and provider systems. Published content already sent to TikTok remains subject to TikTok's controls.

The media-deletion eligibility conditions in Section 5 are mandatory safeguards, not confirmation that automated cleanup is enabled. Backups must have documented coverage, access controls, and protection appropriate to their contents. The owner shall define recovery objectives (RPO/RTO) in a future approved operational plan. Restoration tests must run in isolated environments, record scope/results, correct failures, and be repeated after remediation. A prior local exercise did not demonstrate successful restoration; recovery capability is not established. No Cloud or production backup/recovery claim is made.

11. Third parties and privacy

Known project providers include Supabase, Vercel, and TikTok. Exact services, subprocessors, purposes, data categories, contractual terms, regions, backup/log locations, and transfer mechanisms remain to be verified. The project shall maintain a provider/subprocessor register and review it before enabling new processing. Do not

confirm “United States” or any other Partner Center data-location answer based on provider name, hostname, or this policy.

The operator’s controller or processor role must be determined for each processing activity, purpose, contract, and instruction. Applicable legal bases, LGPD duties, international transfers, and data-subject request deadlines require qualified legal review. This policy is not a legal opinion or certification and does not claim full LGPD compliance, ISO 27001, SOC 2, independent audit, or TikTok approval.

12. Review, exceptions, and approval

Review this policy at least annually and after a material change or incident. Exceptions must record scope, justification, risk, compensating controls, accountable approver, expiry, and remediation. The owner must reconcile the public-policy version conflict and approve the exact document version before it is represented as effective. Publication and TikTok submission require separate authorization. The Security Control Evidence Matrix records local evidence, owner confirmations, deployment status, and outstanding verification; this policy’s requirements do not themselves prove adoption, deployment, or operation.

Approval record: Legal operator: 56.151.919 DIOGO NASCIMENTO DOS SANTOS (MEI holder) · Approver: pending · Decision: pending · Approval/effective date: pending · Publication: not authorized or verified.

Version history

Draft 1.1 (2026-11-02): consolidated security and privacy requirements; approval/publication conflict unresolved. Draft 1.2 (2026-11-02): added owner-confirmed incident coordination and regular mailbox review; conditional media-deletion eligibility; OAuth rotation/concurrency requirements; known providers; backup/recovery requirements and limitations. Current status: **DRAFT — PENDING OWNER APPROVAL**.